STAMP/STPA と MRC-EDC を統合した準定量的リスク評価手法の提案

大野 佳寿馬 [1,*]　佐々木 良一 [2]　金子 朋子 [1]

概要：医療機関等の重要インフラを標的としたランサムウェア被害が相次いでいる．対策の選定を支援する手法として，イベントツリーとディフェンスツリーを併用し，コスト制約下で対策の組合せを求める MRC-EDC 手法が提案されている．しかし同手法では，ディフェンスツリーの構成要素が他組織の過去事例から導出された攻撃ステップによって与えられるため，実際に観測された攻撃経路以外の経路を分析対象に含めることが難しい．本稿では，STAMP/STPA と MRC-EDC を統合した STPA-EDC を提案する．対象システムを制御構造として明示し，非安全な制御動作（UCA）およびハザード誘発要因（HCF）から脅威シナリオを導出したうえで，各シナリオを頂上事象とするディフェンスツリーにより攻撃の成立条件を特定する．本手法を大阪急性期・総合医療センターのランサムウェア事例に適用し，制御構造から導出した脅威シナリオに対してディフェンスツリーを構築できることを確認した上で今後の課題をまとめた．

キーワード：STAMP/STPA, MRC-EDC, リスク評価, セキュリティ管理, 脆弱性分析

Proposal of a Semi-Quantitative Risk Assessment Method Integrating STAMP/STPA and MRC-EDC

Kazuma Ohno[1,*]　Ryoichi Sasaki [2]　Tomoko Kaneko [1]

Abstract: Ransomware attacks against critical infrastructure such as medical institutions continue to occur. The MRC-EDC method has been proposed to support countermeasure selection, combining event tree and defense tree analysis to determine a set of countermeasures under cost constraints. However, in this method the elements of the defense trees are given by attack steps derived from past incidents at other organizations, making it difficult to include attack paths other than those actually observed. This paper proposes STPA-EDC, which integrates STAMP/STPA with MRC-EDC. The target system is described as a control structure, threat scenarios are derived from Unsafe Control Actions (UCA) and Hazard Causal Factors (HCF), and the conditions under which each attack holds are identified through a defense tree with the scenario as its top event. The method was applied to the ransomware incident at Osaka General Medical Center, confirming that defense trees can be constructed for threat scenarios derived from the control structure, and the remaining issues are summarized.

Keywords: STAMP/STPA, MRC-EDC, Risk Assessment, Security Management, Vulnerability Analysis

1. はじめに

近年，社会システムを標的としたサイバー攻撃は年々増加傾向にある．中でも医療機関などの重要な社会インフラを標的としたランサムウェア被害が相次いでおり，その影響は，組織内の情報資産の被害に留まらず，社会全体に影響を及ぼしている．

こうした状況下では，実際に被害が発生した後にその経路をたどって分析するだけでは，再発防止として十分であるとは言えない．実際に攻撃が起きる前に分析を行い，十分な対策を施しておくことが望ましい．

これに対し MRC-EDC(Multiple-Risk-Communicator-Event tree and Defense tree Communicator) [1][2][3]は，コスト制約下で残存リスクを最小化する対策の組合せを求める標的型攻撃に特化した準定量的リスク評価手法として提案されている．同手法は 7 つのステップから構成される．まず分析対象を決定し（ステップ 1），標的型攻撃を分析する（ステップ 2）．次にイベントツリー分析により攻撃の流れをシーケンスとして表現し，各シーケンスの発生確率と影響額からリスクを算出する（ステップ 3）．各シーケンスを構成する事象の成功確率は，ディフェンスツリー分析により算出する（ステップ 4）．そのうえで対策案を作成し（ステップ 5），目的関数と制約条件を決定して（ステップ 6），最適な対策案の組合せを求める（ステップ 7）．このうち，木の構造を決定するのはステップ 1・2 である．ステップ 1 では，組織の人数，PC およびサーバの種類や数，ネットワーク構成，守る対象を把握し，前提条件として設定する．ステップ 2 では，詳細な報告書が公開されている過去のインシデントを参照事例とし，そこから攻撃シーケンスを導出する．一方で従来の方法であると，実際に，攻撃される前のシス

1 創価大学大学院 理工学研究科
Graduate School of Science and Engineering, Soka University
2 東京電機大学
Tokyo Denki University

*e25m5340@soka-u.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

テムに対しては，攻撃シーケンスの導出が難しい．対象のシステムの構造を特定し，制御構造に起因した脅威シナリオからディフェンスツリーを構築する必要がある．

そこで本研究では，安全分析手法 STAMP/STPA(Systems-Theoretic Accident Model and Processes)[4][5][6]と MRC-EDC を統合した STPA-EDC を提案する．本手法により，対象システムを制御構造として明示し，非安全なコントロールアクション（UCA）およびハザード誘発要因（HCF）を特定後，それらから抽出されるシナリオをディフェンスツリーの頂上事象として用いることで，それらの脅威シナリオが成立しうる条件を，システム構成に基づいて導出できる．ディフェンスツリーと対象のシステムの制御構造と対応させることで，実際に攻撃された経路以外の脅威シナリオも生成することができ，ディフェンスツリーを用いることで，それらの攻撃成立条件も明らかにできる．これにより，従来の手法で行われていたネットワークやシステム構成の把握を STAMP/STPA で行うことで，攻撃される段階の前においても分析が可能となり，システムの制御構造に起因した脅威シナリオからディフェンスツリーを構築する．

2. 研究目的

本研究の目的は，本手法の効果として挙げたシステム構成を制御構造から把握した上で，脅威シナリオを抽出し，それらが成立する条件を導出できるか，検証することにある．適用事例として，詳細な報告書[9]が上がっていることから，大阪急性期医療センターのランサムウェア事例を用いることにした．よって検証課題を以下のように設定した．

・検証課題 1　STPA で非安全な制御構造や要因を特定することで脅威シナリオそのものが実際に攻撃された以外のシナリオも特定できているのか

・検証課題 2　STPA で特定した脅威シナリオを頂上事象としてディフェンスツリー分析を行うことで，攻撃が成立しうる条件を特定できているのか

これら 2 つの検証課題を満たすことで，従来手法と同じように分析が行えることを示す．

3. 先行研究

3.1 STAMP/STPA

STAMP/STPA は，STAMP モデルに基づく安全分析手法である．STAMP は，2004 年 Nancy Leveson によって提唱されたシステム理論に基づく安全解析方法論である．FMEA や FTA のような，システムの部品やコンポーネントを単一として捉え，故障不具合に着目するのではなく，人や社会といった要素全体を 1 つのシステムとして捉え，それらコンポーネント間の制御関係に内在する創発的リスクに着目した理論である．STPA とは，システムに内在するハザード要因を特定することができる手法である．これまで，Basic-MRC との統合は検討されており，マトリクス評価にて抽出した HCF の重要度を評価し，スクリーニング，HCF に対して対策案をあげた上で最適な組み合わせを考案している[7]．また現在に至るまで，STPA とアタックツリーの接続方法は検討されてきており，Sidhu[8]は，UCA をアタックツリーの頂上事象とし，その枝から脅威シナリオを導出した．本研究では，脅威シナリオを頂上事象とするディフェンスツリーを構築し，MRC-EDC への接続手段とした点に，また STAMP/STPA での特定した広義リスク(HCF)を定量的に評価する手法の 1 つとしても価値があることであると考える．

3.2 MRC-EDC

MRC-EDC は，既存の Basic-MRC に加え，イベントツリー・ディフェンスツリーにより，攻撃事象の出現確率を用いた攻撃シーケンスごとの評価や，対策前後によるリスク低減値から対策案を評価できる．従来のアタックツリーを用いた手法では，攻撃シーケンスの肥大化や，シーケンスの数だけ木を構築することによる膨大な作業量が課題となっていた．また対策の組合せをどこまで実施すればよいかの判断基準が経営者に与えられない．相原らは，攻撃シーケンスを枝分かれで簡潔に表現できるイベントツリーと，各段階の対策の効果を記述しやすいディフェンスツリーを併用することでこれらを解決し，コスト制約下で総合リスクを最小化する対策の組合せを求める手法を EDC 手法として提案した．以下本手法を従来の手法と呼ぶ．また佐々木らは，これを改良し，生成 AI による対人攻撃のリスク評価へ適用範囲を広げた．

4. 分析手順

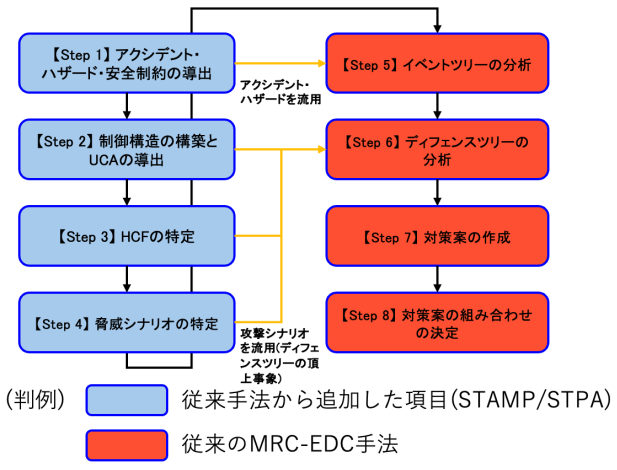


図 1　STPA-EDC の分析手順

Fig.　1　Analysis procedure of STPA-EDC

© 2026 Information Processing Society of Japan

5. STPA-EDC

5.1 Step1　アクシデントとハザード,安全制約

本節では，以降の UCA 抽出およびロスシナリオ分析の起点となる評価軸として，本事例におけるアクシデント，ハザード，および安全制約を特定する．ここでのアクシデントは，標的型攻撃にあった最終的なシステムにおける損失，ハザードは，このアクシデントに至る過程で対象システムが取り得る状態として定義する．本事例は，既に攻撃を受けているため，電子カルテを暗号化されたことによる医療情報システムの停止をアクシデントと設定した．本事例では，攻撃者が段階的に内部へ侵入し最終的に電子カルテを暗号化するに至る過程を，制御構造上の到達段階として捉え，以下の状態をハザードとして特定した．これらをイベントツリー分析のイベントとして設定している．またハザードに対しての安全制約も設定した（表１）．

表 1　STPA-EDC Step1 試行結果の一部

Table 1　Results of STPA-EDC Step1

アクシデントID	アクシデント	ハザードID	ハザード	安全制約ID	安全制約
A1	カルテが暗号化されて医療システムが停止する	H1	カルテを暗号化する	SC1	カルテを暗号化されない
		H2	基幹システムに侵入	SC2	基幹システムに侵入されない
		H3	サーバーBに侵入する	SC3	サーバーBに侵入されない
		H4	サーバーAに侵入する	SC4	サーバーAに侵入されない
		H5	FW-Zを突破する	SC5	FW-Zを突破されない

5.2 Step2　制御構造の構築と UCA の導出

本節では，システムコンポーネント間の制御構造(Control Action)を特定した．病院の医療システムのみを対象とし，制御関係を明示したコントロールストラクチャを構築した（図 2）．また特定した CA をもとに，非安全な制御構造(Unsafe Control Action)を４つのヒントワード，「Not Providing」「Providing causes hazard」「Too early/Too late」「Stop too soon/Applying too long」から導出した．

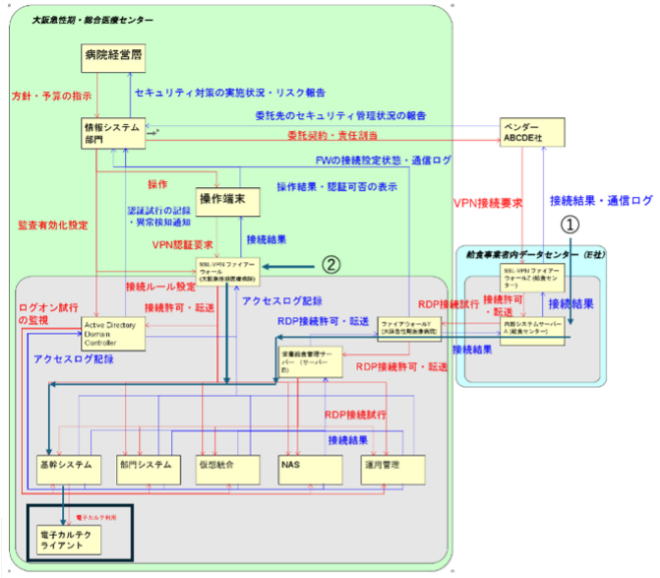


図 2　STPA-EDC Step2　コントロールストラクチャー

Fig.　2　STPA-EDC Step2　Control Structure

表 2　STPA-EDC Step2　試行結果の一部

Table 2　Results of STPA-EDC Step2

対応するCA	From	To	Not Providing(N)	Providing causes hazard(P)	Too early / Too late(T)	Stop too soon / Applying too long(D)
利用要求の認証・許可	基幹システム	電子カルテクライアント	(UCA1-N-1) 電子カルテにアクセスできない	(UCA1-P-1) 意図していないユーザーの認証要求を通してしまう	(UCA1-T-1) 電子カルテにアクセスできるまで時間がかかり過ぎる	(UCA1-D-1) 正当でないセッションを永続化させる
RDPログオン認証	内部各サーバ	サーバーB	(UCA2-N-1) 認証要求をサーバBが送らない。/(UCA2-N-2) 各サーバが認証結果を送らない	(UCA2-P-1) 意図していないユーザの認証要求を通してしまう	(UCA2-T-1) 認証結果を送るのが遅い/ (UCA2-T-2) 認証結果を受け取るのに時間がかかる	(UCA2-D-1) 正当でないRDPログオンの許可を解除せず継続する
RDP通信許可・転送	SSL-VPN ファイアーウォールZ(給食センター)	サーバーA(給食)	(UCA3-N-1) ファイアーウォールが接続要求を送らない。/ (UCA3-N-2) サーバAが認証結果を送らない	(UCA3-P-1) 意図していない外部接続元からのRDP接続を許可する	(UCA3-T-1) ファイアーウォールが接続許可要求を送るのが遅い/ (UCA3-T-2) 許可を受け取るのに時間がかかる	(UCA3-D-1) リモート保守用VPN接続口を保守作業時以外も有効なまま維持する
RDPログオン認証	栄養給食管理サーバー（サーバーB）	サーバーA(給食)	(UCA4-N-1) サーバAが接続要求を送らない。/(UCA4-N-2) サーバーBが認証結果を送らない	(UCA4-P-1) 許可されていない接続元からのRDPログオンを認証する	(UCA4-T-1) サーバーAが接続許可要求を送るのが遅い/(UCA4-T-2) 許可を受け取るのに時間がかかる	(UCA4-D-1) 保守用のRDP受付を作業時以外も有効なまま維持する
RDP通信許可・転送	ファイアーウォールY	サーバーB	(UCA5-N-1) ファイアーウォールYが接続要求を送らない。/(UCA5-N-2) サーバーBが認証結果を送らない	(UCA5-P-1) サーバーBへ意図していないRDP接続を許可する	(UCA5-T-1) サーバYが接続許可要求を送るのが遅い/(UCA5-T-2) 許可を受け取るのに時間がかかる	(UCA5-D-1) 保守用に許可したRDP転送ルールを作業後も解除せず残す
VPN認証	FW-Z	ベンダー端末	(UCA6-N-1) 端末が接続要求を送らない。/(UCA6-N-2) FW-Zが認証結果を送らない	(UCA6-P-1) 意図していないユーザの認証要求を通してしまう	(UCA6-T-1) ベンダーの端末が接続許可を送るのが遅い/(UCA6-T-2) 許可を受け取るのに時間がかかる	(UCA6-D-1) 認証済みVPNセッションを保守作業終了後も維持する
RDPログオン認証	サーバーA	ベンダー端末	(UCA7-N-1) ベンダーから認証要求が送られない/(UCA7-N-2) サーバーAが認証結果を送らない	(UCA7-P-1) 意図していないRDP接続を許可する	(UCA7-T-1) ベンダーの端末が接続許可を送るのが遅い/(UCA7-T-2) 許可を受け取るのに時間がかかる	(UCA7-D-1) 保守用のRDP受付を作業時以外も有効なまま維持する
プログラムの実行許可・遮断	OS	基幹システム		(UCA8-P-2) 不正なプログラムの実行を許可する	(UCA7-T-1) プログラムの実行許可・遮断を出すのが遅い	

© 2026 Information Processing Society of Japan

表 3　STPA-EDC Step3,4　試行結果の一部
Table 3　Results of STPA-EDC Step3,4

From	To	UCA	HCF	攻撃シナリオ
OS	基幹システム	(UCA8-P-2) 不正なプログラムの実行を許可する	(HCF8-P-1-1) 一部のサーバ・機器にウイルス対策ソフト・EDRが導入されていない	(AS8-P-1-1-1) ウイルス対策ソフト・EDRが未導入の機器上で暗号化プログラムを実行する
			(HCF8-P-1-2) 既知シグネチャに基づく判定であり、未知の検体を判定できない	(AS8-P-1-1-2) 既存の検体を改変し、照合対象と一致しないプログラムとして実行する
			(HCF8-P-1-3) 管理者権限によりEDR及び対策ソフトの停止が可能である	(AS8-P-1-1-3) 管理者権限を利用し、対策ソフトのアンインストールを行う。
			(HCF8-P-1-4) ウイルスの定義ファイルにマッチングしなかった。	(AS8-P-1-1-4) 定義ファイルに含まれない既知の検体を用いて実行する

5.3　Step3,4　HCF・脅威シナリオの特定

各 UCA について，どのような原因によってハザードとなり得るのか，すなわち HCF を特定した（表 3）．UCA では，「電子カルテにアクセスできない」，「許可されていない接続元からの接続を許可する」などの非安全な制御構造を特定し，それらを誘発する可能性のある要因を列挙した．本研究においては，実際に想定される要因をもとに評価をする必要がある．よって，事実的に発生しない HCF に関しては対象外にする必要がある．また抽出した HCF に対して，その損失が発生する可能性のあるシナリオを導出する．

5.4　Step5　イベントツリー分析

従来の手法では，ステップ 1・2 において，分析対象の決定と標的型攻撃の分析を行なっていたが，本手法では，STAMP/STPA の手順の一貫として行なっているため省く．コントロールストラクチャや UCA を元に，イベントツリー分析を構築し，フェーズごとに突破成功率 BT(Breach probability of a Top event)を推定する．本節におけるイベントツリーの説明は 5．1 節で特定したアクシデント・ハザードを元に作成したイベントツリーを用いる(図 3)．攻撃の進行を，初期潜入(BT1,2)，基盤構築(BT3)，内部侵

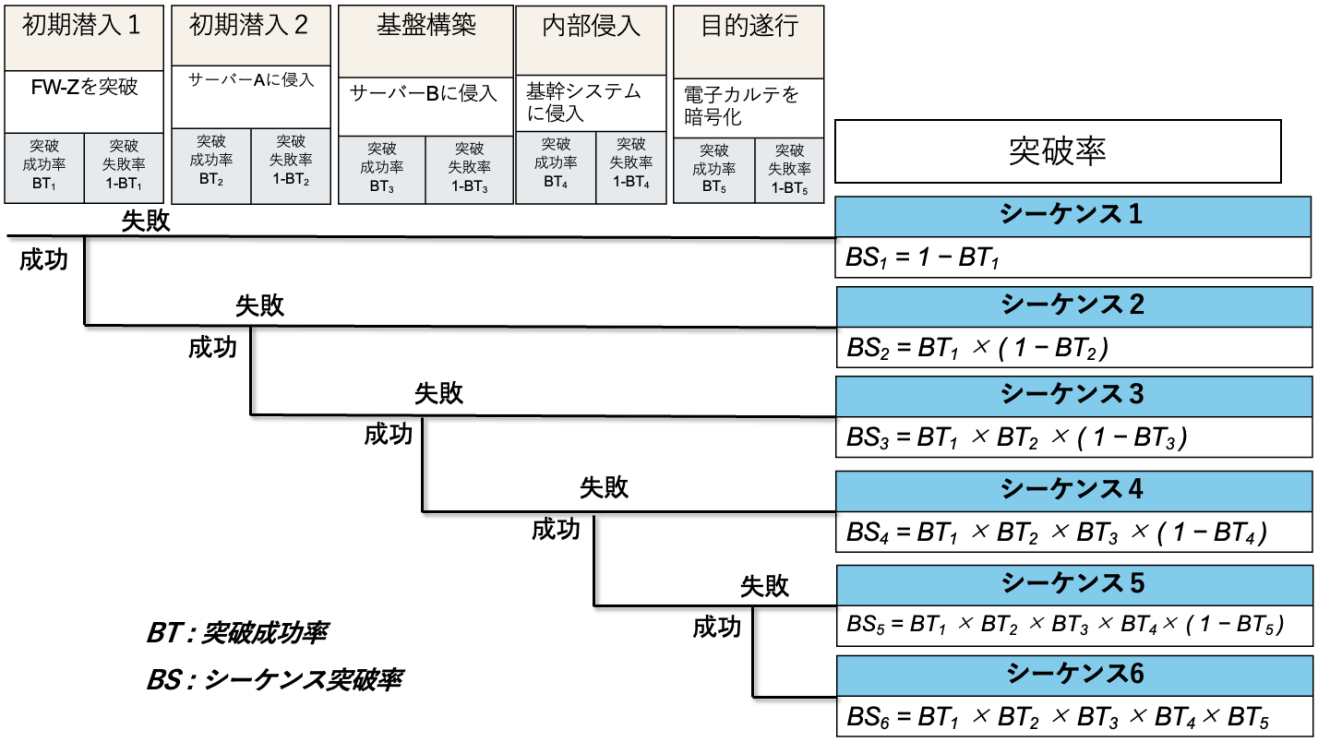


図 3　STPA-EDC Step 5　イベントツリー分析
Fig. 3　Results of STPA-EDC Step5

© 2026 Information Processing Society of Japan

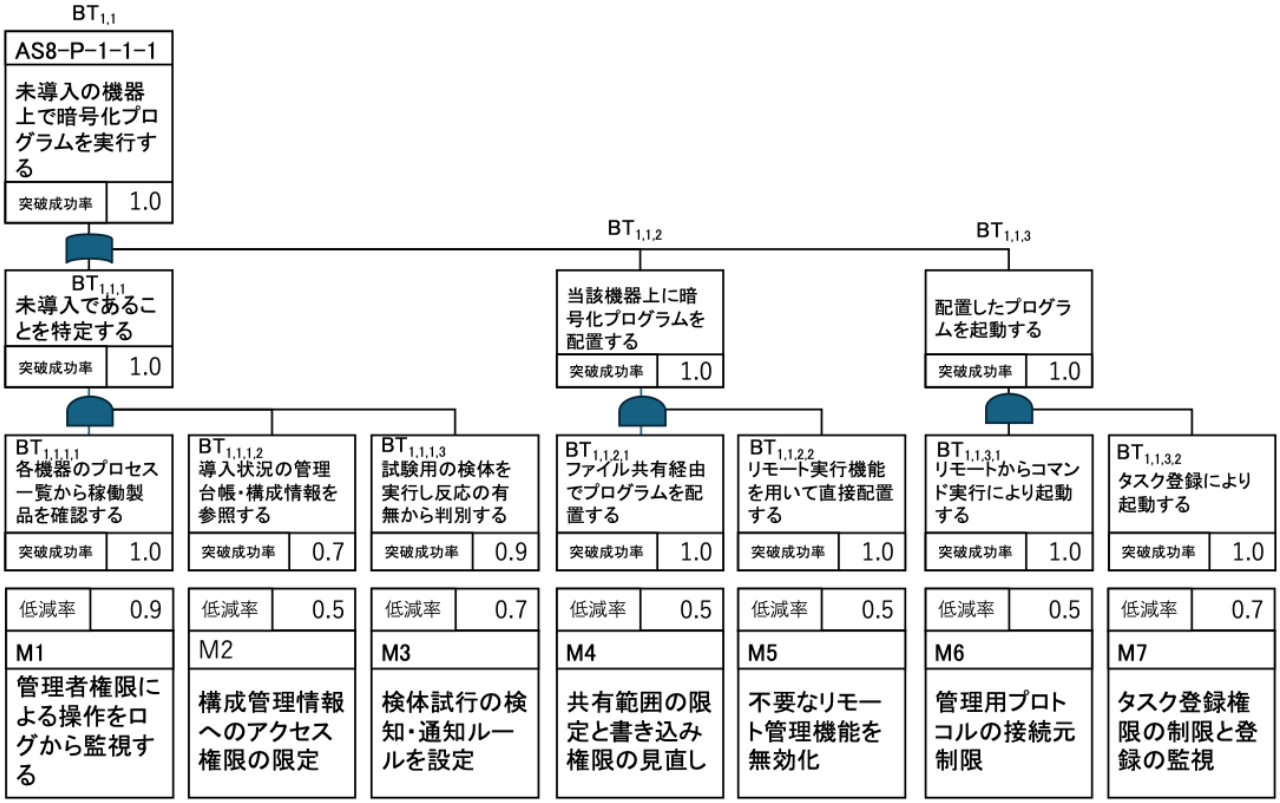


図 4　STPA-EDC Step6　試行結果 ディフェンスツリー1

Fig.　4　Result of STPA-EDC Step6 Defense Tree 1

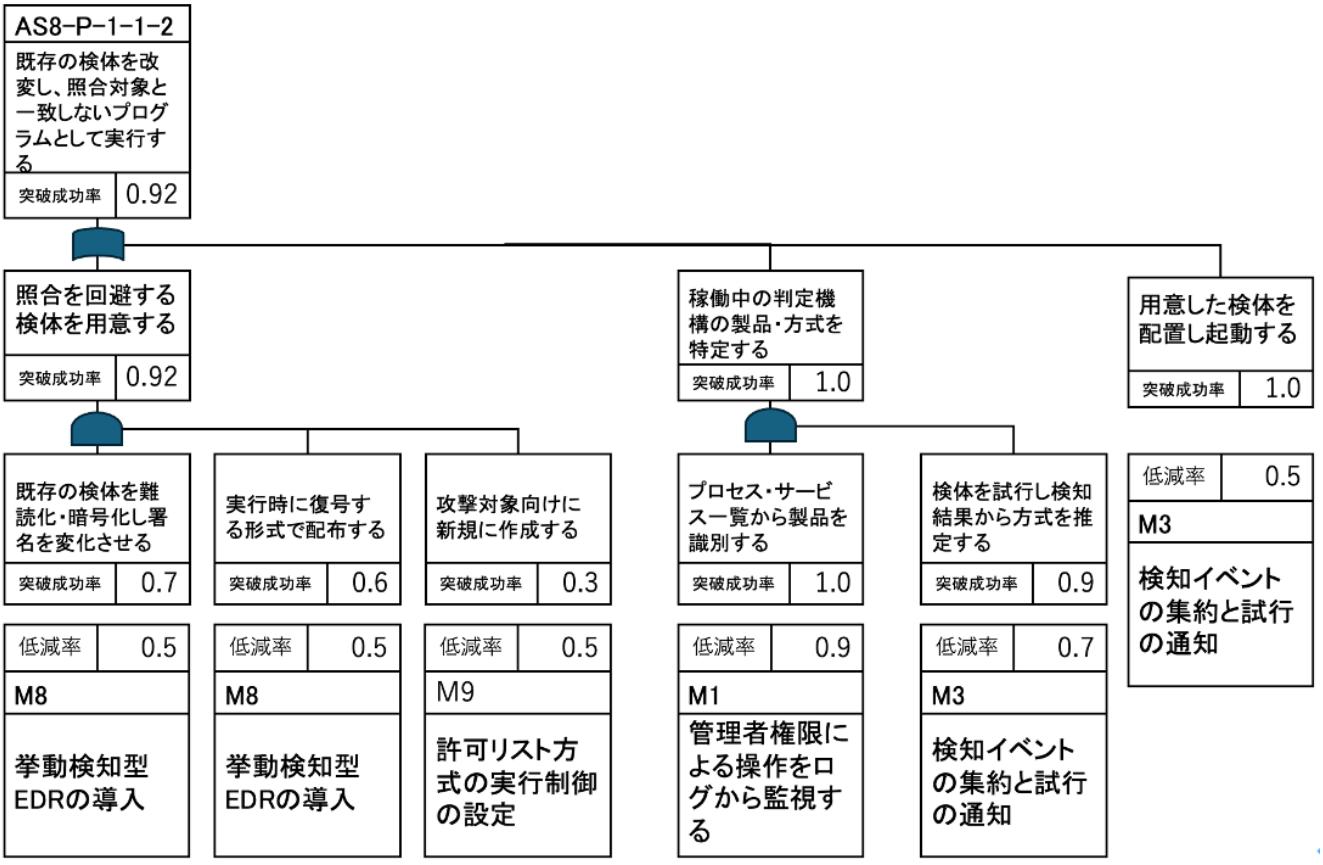


図 5　STPA-EDC Step6　試行結果 ディフェンスツリー2

Fig.　5　Result of STPA-EDC Step6　Defense Tree 2

© 2026 Information Processing Society of Japan

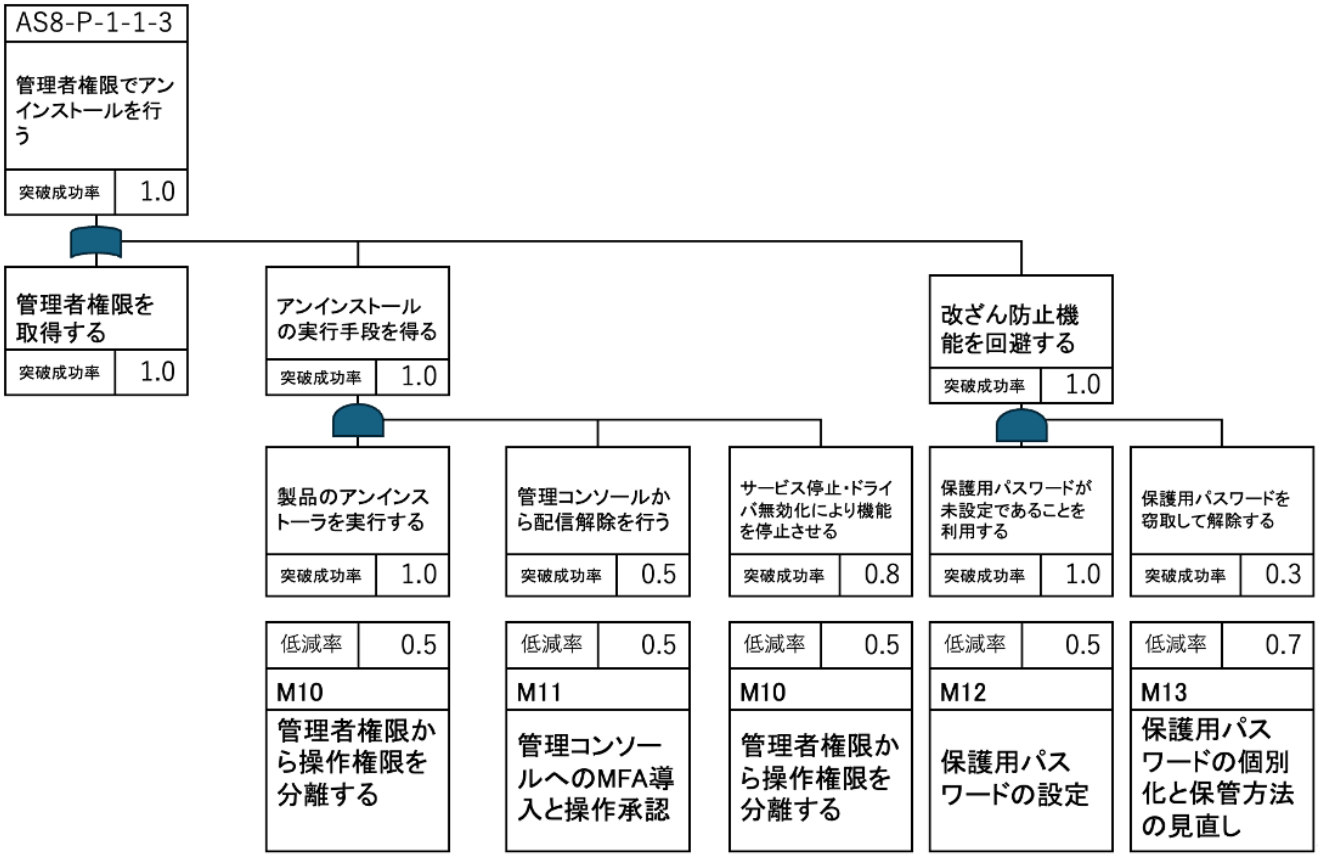


図 6　STPA-EDC Step6　試行結果 ディフェンスツリー3

Fig. 6　Result of STPA-EDC Step6　Defense Tree3

入 (BT4)，目的遂行(BT5)の 5 フェーズからなるイベントツリーとして表現する．攻撃者は各フェーズを順に突破して深部へ到達し，いずれかのフェーズで突破に失敗した場合，その段階で攻撃は停止する．各フェーズの突破成功率を BT_k(k = 1, …, 5)とし，これは各フェーズをもとに構築したディフェンスツリーを合成して得られる（図 3）．攻撃が到達した段階に応じて，攻撃シーケンス BS_1 から BS_4 を定義する．各シーケンスの到達スコアは，そこに至るまでの各フェーズを突破し，その先のフェーズで停止する条件付き確率として，次式で与えられる(1)～(6)．

$$BS_1 = 1 - BT_1 \quad (1)$$

$$BS_2 = BT_1 \cdot (1 - BT_2) \quad (2)$$

$$BS_3 = BT_1 \cdot BT_2 \cdot (1 - BT_3) \quad (3)$$

$$BS_4 = BT_1 \cdot BT_2 \cdot BT_3 \cdot (1 - BT_4) \quad (4)$$

$$BS_5 = BT_1 \cdot BT_2 \cdot BT_3 \cdot BT_4 \cdot (1 - BT_5) \quad (5)$$

$$BS_6 = BT_1 \cdot BT_2 \cdot BT_3 \cdot BT_4 \cdot BT_5 \quad (6)$$

5.5 Step6　ディフェンスツリー分析

イベントツリーの各フェーズの突破成功率 BT_k を，ディフェンスツリーにより算出する．すなわち，ディフェンスツリー一つがイベントツリーの一フェーズに対応し，フェーズを頂上事象として，その突破に必要な手段や要因を STAMP/STPA で抽出した非安全な制御構造(UCA)，ハザード要因(HCF)，シナリオをもとに対応させる．具体的なディフェンスツリー構築手順を「電子カルテを暗号化」のイベントを例として用いて説明する．

電子カルテの暗号化においては，表 2 より，OS と基幹システムの制御作用であるプログラムの実行許可・遮断が関連しており，それらの脅威シナリオとして，「ウイルス対策ソフト・EDR が未導入の機器上で暗号化プログラムを実行する」(AS8-P-1-1-1)，「既存の検体を改変し，照合対象と一致しないプログラムを実行する」(AS8-P-1-1-2)，「管理者権限を利用し，対策ソフトのアンインストールを行う」(AS8-P-1-1-3)，「定義ファイルに含まれない既知ファイルの検体を用いて実行する」(AS8-P-1-1-4)が抽出された．このうち実際の報告書[9]からウイルス対策ソフトのファイルの更新は随時行なっていたことがわかったため，これは除外とし，他の 3 つのシナリオを頂上事象としたディフェンスツリー分析を行った．以下に 3 つのディフェンスツリーの説明を行う．

まず図 4 より「ウイルス対策ソフト・EDR が未導入の機器上で暗号化プログラムを実行する」(AS8-P-1-1-1)に対して，未導入であることを特定し，プログラムを配置，配置したプログラムを起動する必要がある．未導入であることを特定するには，管理者権限等でログオンした機器上で稼働中のサービスを一覧表示し，対策製品のプロセス名が存在しないことを確認する，又はシステム管理部門が保有す

© 2026 Information Processing Society of Japan

る導入状況の一覧表や構成管理ツールを参照する，検知されることが分かっている無害な検体を実行し，警告が出ないことで未導入と判断する，などが挙げられる．また機器上にプログラムを配置するには，管理者権限で接続可能な共有フォルダにプログラムをコピーするか，RDP やリモート管理機能を使い，対象機器上に直接ファイルを作成する必要がある．そしてプログラム自体を実行する上では，遠隔からコマンドを送り，配置したプログラムを直接起動するか，OS のタスクスケジューラに登録し，深夜など人の目が少ない時間に自動起動させる必要がある．

次に「既存の検体を改変し，照合対象と一致しないプログラムを実行する」(AS8-P-1-1-2)に対しては，まず検体を用意し，攻撃対象のシステムに用いられている判定機構を把握した上で，起動を行う必要がある（図 5）．検体を用意する上では，既存のランサムウェアにパッキングや暗号化を施し，ファイルの特徴値を変えるか，ファイル自体には暗号化コードを含めず，実行時にメモリ上で復号して動作させるか，既存の検体を使わず，この標的専用に暗号化プログラムを作成するかのいずれかが考えられる．次に，対象システムのウイルス対策ソフトや EDR の判定機構を把握するには，稼働中のサービス名から製品名とバージョンを特定し，その製品の検知方式を調べるか，結果から方式を推定改変の度合いを変えた複数の検体を順に実行し，どこまで通過するかを確認する方法が考えられる．

最後に，「管理者権限を利用し，対策ソフトのアンインストールを行う」(AS8-P-1-1-3)は，実際の脅威シナリオである（図 6）．本シナリオには，まず管理者権限を取得し，アンインストールの実行を行い，アンインストールという不正な操作を防止する機能を回避する必要がある．管理者の権限を取得するには，別のサーバーの制御構造から考える必要があり，別のディフェンスツリーの分析を必要とするため，省略する．アンインストールの実行手段を知るには，製品に付属する削除プログラムをそのまま実行するか，中央管理サーバに接続し，対象機器を配信対象から除外するか，削除せず，OS のサービス管理機能で動作を止めるか，などが検討される．報告書には，実際どのようになっていたかは言及されていないため，予測として並べる．そして不正な操作を防止する機能を回避する上で，保護パスワードが未設定であれば，そのまま実行し，保護が設定されている場合に，管理サーバや文書からパスワードを入手し，正規の手順で解除するなどが考えられる．

それぞれの事象に対しては，従来の MRC-EDC と同様に，ゲートを設定する．ゲートには AND と OR があり，すべての原因事象が揃って初めて頂上事象が成立する場合は AND ゲート，いずれか一つの原因事象で成立する場合は OR ゲートを用いる．以下，事象 x と事象 y について x OR y を「x, y」，x AND y を「xy」と表す．また，事象 x の突破成功率を BT_x とする．AND および OR の計算は次の式を用いる(7)(8).

$$\text{AND: } BT_{x\gamma} = BT_x \times BT_\gamma \quad (7)$$

$$\text{OR: } BT_{x,\gamma} = 1 - (1 - BT_x) \times (1 - BT_\gamma) \quad (8)$$

各下位事象に対して突破成功率を推定する．発生割合や突破成功率の数値に関しては，相原らが言及するように，絶対的な算出根拠は存在しないため，統計データや，関係者の討議で決まった値などを用いることが望ましい．本手法では，各下位事象(HCF)に，突破成功率を割り当てる．突破成功率の値は，報告書と照らし合わせ，実際に行われた事象に対しては，1 を設定し，確認できないものに対しては，特別な準備を要さず，管理者権限があれば実行できる場合には，0. 9，準備または追加の到達を要する場合は，0．6，高い技術的コストまたは別系統の情報入手を要する場合は，0．3 を設定した．

具体的な計算方法としてディフェンスツリー 1 (図 4)の場合を用いて示す．まず中間事象の計算は以下の数式(9)(10)(11)(12)になる．また頂上事象においては以下のような数式になる．

$$BT_{1,1,1} = 1 - (1 - BT_{1,1,1,1})(1 - BT_{1,1,1,2})(1 - BT_{1,1,1,3})$$
$$= 1 - (1 - 1.0)(1 - 0.7)(1 - 0.9) = 1.0 \quad (9)$$

$$BT_{1,1,2} = 1 - (1 - BT_{1,1,2,1})(1 - BT_{1,1,2,2}) = 1 - (1 - 1.0)(1 - 1.0) = 1.0 \quad (10)$$

$$BT_{1,1,3} = 1 - (1 - BT_{1,1,3,1})(1 - BT_{1,1,3,2}) = 1 - (1 - 1.0)(1 - 1.0) = 1.0 \quad (11)$$

$$BT_{1,1} = BT_{1,1,1} \times BT_{1,1,2} \times BT_{1,1,3} = 1.0 \times 1.0 \times 1.0 = 1.0 \quad (12)$$

5.6 Step7　対策案の設定

対策案の設定においては，5．5 節で特定した下位事象に対して，それぞれ設定し，対策案の低減値も設定した．本来突破成功率と同じように，絶対的な値は存在しないため，関係者が討議して値を決定することが望ましい．対策における低減率を考慮した計算方法は以下のようになる(13)(14)(15).

$$Bt_{1,1,1,1} = 1.0 \times (1 - M_1) + 1.0 \times \{(1 - 0.9) \times M_1\} \quad (13)$$

$$Bt_{1,1,1,2} = 0.7 \times (1 - M_2) + 0.7 \times \{(1 - 0.5) \times M_2\} \quad (14)$$

$$Bt_{1,1,1,3} = 0.9 \times (1 - M_3) + 0.9 \times \{(1 - 0.7) \times M_3\} \quad (15)$$

M_i は，対策の状態を表し，実施した場合に $M_i = 1$, 実施しない場合に $M_i = 0$ となる．また対策をとった場合の，中間事象，頂上事象の計算式は，以下のようになる(16).

$$BT_{1,1,1}' = 1 - (1 - 0.1)(1 - 0.35)(1 - 0.27)$$
$$= 1 - 0.90 \times 0.65 \times 0.73 = 0.573 \quad (16)$$

5.7 Step8　対策案の組み合わせ設定

STPA 手法を用いたことによる効果が確認できていない

© 2026 Information Processing Society of Japan

ことと，既に大阪急性期医療センターでは多くの対策が講じられていることからイベントツリーを用いてのリスク値による対策案の選定は行わない．これらを行うことは今後の課題としておく．

6. 検証

6.1 検証 1：攻撃されたシナリオ以外のシナリオの特定

2 節で設定した研究目的に対する評価を，実際に特定したシナリオと大阪急性期医療センターから提出された報告書を照らし合わせてながら行う．まず UCA8-P-2「不正なプログラムの実行を許可する」から抽出した HCF および脅威シナリオについて，調査報告書における記載の有無を以下に示す．

抽出された 4 件のうち，報告書に記載があるのは 3 件であった．AS8-P-1-1-2 は，実際の攻撃では選択されなかったが，対象システムにおいて成立しうるシナリオとして導出された．これは，コントロールストラクチャー上に OS によるプログラムの実行制御が記述され，その UCA「不正なプログラムの実行を許可する」から「既知のシグネチャであり，未知の検体を検出できない」という HCF から導かれた．

一方 AS8-P-1-1-4 は，定義ファイルを定期的に更新する仕組みが構築されていたとの記載により，前提が成立しないと判断してディフェンスツリー分析は行わなかった．除去の判断は対象システムの構成に関する記述に基づいている．以上より，検証課題 1 については，実際に攻撃されたシナリオ以外のシナリオが特定された．

表 4　STPA-EDC 検証課題結果

Table4　Result of STPA-EDC

脅威シナリオ	報告書の記載	ディフェンスツリー分析
(AS8-P-1-1-1) ウイルス対策ソフト・EDRが未導入の機器上で暗号化プログラムを実行する	△（ウイルス対策ソフトは導入済み）	○
(AS8-P-1-1-2) 既存の検体を改変し、照合対象と一致しないプログラムとして実行する	×	○
(AS8-P-1-1-3) 管理者権限を利用し、対策ソフトのアンインストールを行う。	○	○
(AS8-P-1-1-4) 定義ファイルに含まれない既知の検体を用いて実行する	○	×

（判例）○　記載がある　△ 一部記載がある　× 記載がない

6.2 検証 2　攻撃が成立しうる条件の特定

5．3 節で特定した各シナリオを頂上事象とし，その成立に必要な条件を下位事象として展開したディフェンスツリーを構築した．これにより，その脅威シナリオを成立するにあたり，攻撃者が実際に行う手順を明確にできた．一方で，全ての UCA，HCF，脅威シナリオに対するディフェンスツリーを分析することは行えていない．

7. 考察

本研究では，従来手法で行なっていたネットワーク構成や機器などのシステム構成についての把握を STAMP/STPA を用いて行なった上で，イベントツリー分析やディフェンスツリー分析を行なった．STAMP/STPA のフローを踏むことで，制御構造上のコントロールアクションから UCA を導出し，HCF を経由して脅威シナリオを特定するため，シナリオの導出根拠が対象システム自身の構成に置かれる．また検証 1，2 より，STAMP/STPA の UCA，HCF から導出される脅威シナリオを頂上事象とすることで，従来と同様にディフェンスツリーを構築することが可能となった．

8. 今後の展開

本研究において，従来の方法の一部を STAMP/STPA へ代用することは可能であることがわかったが，STAMP/STPA を用いることでの従来の方法と比較したメリットが確認されていない．これについては，5．5 節以外の脅威シナリオを特定する必要があり，表 2 で示した他の UCA から HCF や脅威シナリオを特定した上で，ディフェンスツリーを構築し，従来の方法と比較する必要があると考える．また今後，Step8 以降の対策案の組み合わせ選定においても効果があるか他事例を用いて検証していく．

参考文献

[1] 佐々木良一.多重リスクコミュニケータ MRC シリーズの段階での開発状況と今後の展開. CSS2025, 2025.

[2] 相原遼，石井亮平，佐々木良一．イベントツリーとディフェンスツリーを併用 した標的型攻撃に対するリスク分析手法の提案と適用．情報処理学会論文誌, 2018, vol.59, no.3.

[3] Sasaki, R. et al.. Development and Trial Application of an Improved MRC-EDC Method. JIP, 2024, vol.32.

[4] 金子朋子．セーフティ&セキュリティ入門．日科技連出版社, 2021.

[5] IPA 独立行政法人情報処理推進機構.はじめての STAMP/STPA ～システム思考 に基づく新しい安全性解析手法～. 2016.

[6] Kaneko, T. and Yoshioka, N.. STAMP S&S: Layered Modeling for the complexed system in the society of AI/IoT. 13th International Joint Conference on Knowledge-Based Software Engineering (JCKBSE2020), 2020, p.122-131.

[7] 佐々木良一，金子朋子，高橋雄志，福澤寧子．リモートメンテナンスを伴い フィードバックを有する IoT システムのリスクアセスメント手法. JSSM 誌, 2021, vol.35, no.3.

[8] Sidhu, A. S.. Application of STPA-Sec for Analyzing Cybersecurity of Autonomous Mining Systems. Working Paper CISL#2018-11, Cybersecurity Interdisciplinary Systems Laboratory, MIT Sloan School of Management,2019, 149p.

[9] 大阪急性期・総合医療センター情報セキュリティインシデント調査委員会．調査報告書. 2023.

© 2026 Information Processing Society of Japan